Luca Danisi **5-5-2026**

Incident Response

1 - Obiettivo :

Analizzare uno scenario di incidente informatico reale in cui il sistema B — un server database — è stato compromesso da un attaccante esterno che ha violato il perimetro di rete accedendo tramite Internet.

In qualità di membri del team CSIRT , l'esercizio richiede di descrivere le procedure operative da adottare in risposta all'incidente, con particolare attenzione a due fasi fondamentali: l'isolamento del sistema compromesso per bloccare l'attacco in corso, e la rimozione sicura del sistema dalla rete. Viene inoltre richiesto di spiegare le tecniche di sanitizzazione dei dati (Clear, Purge e Destroy) da applicare ai dischi prima del loro smaltimento definitivo, al fine di impedire il recupero di informazioni sensibili.

2 - Strumenti utilizzati :

Firewall — utilizzato come primo punto di intervento per bloccare il traffico malevolo proveniente da Internet
Procedure CSIRT — metodologie standard di risposta agli incidenti informatici per la gestione, il contenimento e la rimozione di sistemi compromessi
Tecniche di sanitizzazione dei dati — procedure di tipo Clear, Purge e Destroy per l'eliminazione sicura delle informazioni sensibili presenti sui dischi prima dello smaltimento

3 - Svolgimento

I) Isolamento del Sistema B

L'isolamento ha lo scopo di bloccare l'attacco in corso senza spegnere immediatamente il sistema, in modo da preservare le prove digitali.

Le azioni eseguite sono:

Disconnessione dalla rete — il sistema B viene fisicamente scollegato dalla rete interna, impedendo all'attaccante di continuare ad operare e di spostarsi lateralmente verso gli altri sistemi (A, C, D)

Blocco sul Firewall — vengono create regole specifiche sul firewall perimetrale per bloccare tutto il traffico in entrata e in uscita da e verso l'indirizzo IP del sistema B
Preservazione delle prove — prima di qualsiasi altra azione vengono acquisite le log di sistema, i processi attivi e una copia della memoria RAM, utili per l'analisi forense successiva

II) Rimozione del Sistema B

Una volta isolato, si procede alla rimozione definitiva del sistema compromesso dalla rete aziendale:

Shutdown controllato — il sistema viene spento in modo sicuro
Reinstallazione del sistema operativo — il sistema operativo viene reinstallato da zero su hardware pulito o su una nuova macchina virtuale
Ripristino da backup pulito — i dati vengono ripristinati esclusivamente da un backup precedente alla compromissione
Verifica prima del rientro in rete — prima di ricollegare il sistema alla rete, viene eseguita una scansione completa per verificare l'assenza di malware residui

4 - Sanitizzazione :

Prima di smaltire fisicamente i dischi del sistema B compromesso, è obbligatorio eliminare in modo sicuro tutti i dati sensibili presenti. Esistono tre livelli di sanitizzazione, in ordine crescente di sicurezza:

CLEAR

È il livello base. I dati vengono sovrascritti con valori casuali o zeri, rendendo il recupero difficile con strumenti software comuni. I dati però potrebbero ancora essere recuperati con strumenti forensi avanzati.

Esempio pratico: sovrascrivere il disco con il comando **dd** su Linux.

Utilizzato quando il disco verrà riutilizzato all'interno della stessa organizzazione.

PURGE

È il livello intermedio. I dati vengono eliminati in modo più profondo tramite tecniche avanzate come la sovrascrittura multipla o la cancellazione crittografica. Il recupero dei dati diventa praticamente impossibile anche con strumenti forensi.

Esempio pratico: sovrascrittura multipla con tool come shred su Linux, oppure cancellazione crittografica su dischi SSD.

Utilizzato quando il disco verrà dismesso o ceduto a terzi.

DESTROY

È il livello massimo. Il disco viene fisicamente distrutto tramite triturazione, fusione o smagnetizzazione (degaussing). Non esiste alcuna possibilità di recupero dei dati.

Utilizzato quando il disco contiene dati altamente sensibili e non può essere riutilizzato in nessun caso.

5 – Conclusioni:

Il lavoro di un team CSIRT di fronte a un sistema completamente compromesso , segue un processo ben definito composto da fasi precise: prima si isola il sistema per bloccare l'attacco e preservare le prove, poi si rimuove e si ripristina il sistema in modo controllato.

Altrettanto importante è la fase finale di sanitizzazione dei dischi, dove la scelta tra Clear, Purge e Destroy non è casuale ma dipende dalla sensibilità dei dati contenuti e dalla destinazione finale dell'hardware. Nel caso del sistema B, contenendo dati sensibili di un database aziendale compromesso, la tecnica più indicata sarebbe il **Destroy**, che garantisce la totale impossibilità di recupero delle informazioni.

Analisi Malware (Esercizio Facoltativo)

1 - Obiettivo

Due utenti di una grande azienda segnalano problemi sui loro computer. In qualità di membri del team CSIRT/SOC, viene richiesto di analizzare due link sospetti tramite la piattaforma di sandbox online ANY.RUN, al fine di identificare la natura delle minacce e produrre un report dell'eventuale attacco in corso.

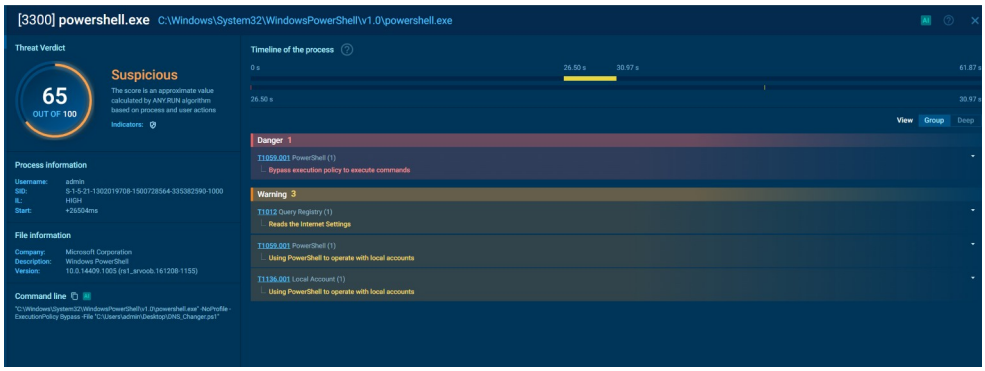
2 - Strumenti Utilizzati

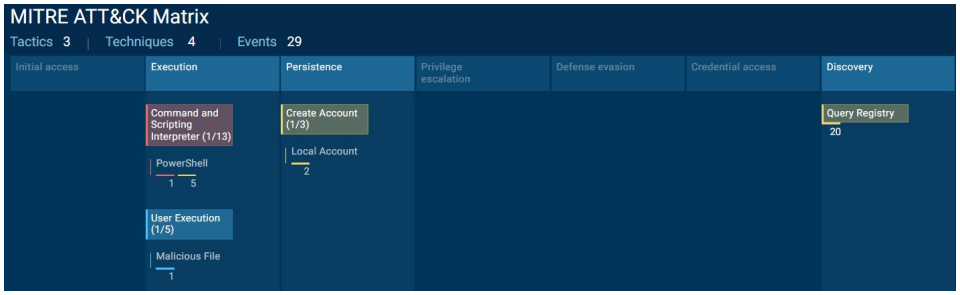
- **ANY.RUN** — piattaforma sandbox online che esegue file e URL sospetti in un ambiente isolato, registrando tutto il comportamento del processo
- **MITRE ATT&CK Framework** — framework standard internazionale per classificare le tecniche di attacco utilizzate dal malware

3 - Risultati

CASO 1 — DNS_Changer.ps1

Verdict: Suspicious (65/100)
File analizzato: DNS_Changer.ps1 — script PowerShell
Comportamento: lo script viene eseguito con il parametro -ExecutionPolicy Bypass, aggirando le protezioni di Windows. Una volta avviato, legge le impostazioni Internet del sistema e tenta di creare account locali tramite PowerShell.
Tecniche MITRE ATT&CK rilevate:
T1059.001 — Esecuzione tramite PowerShell con bypass della policy di sicurezza
T1012 — Lettura delle impostazioni Internet dal registro di sistema
T1136.001 — Creazione di account locali tramite PowerShell
Rischio: il file è probabilmente un malware che modifica le impostazioni DNS della vittima per reindirizzarla su siti falsi o malevoli

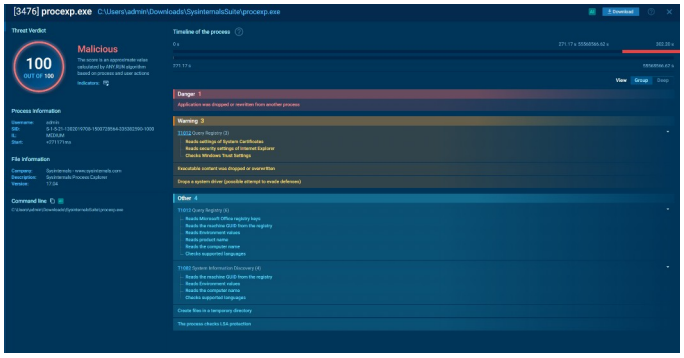


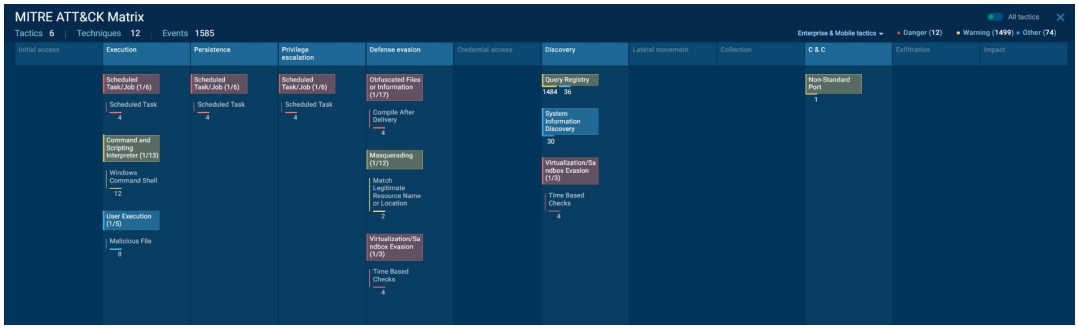


CASO 2 — procexp.exe

- **Verdict:** MALICIOUS (100/100)
- **File analizzato:** procexp.exe — si maschera da Sysinternals Process Explorer, tool legittimo di Microsoft
- **Comportamento:** il file si riscrive autonomamente, installa un driver di sistema per nascondersi, crea task pianificati per sopravvivere ai riavvii e comunica con server esterni su porte non standard
- **Tecniche MITRE ATT&CK rilevate:**
    - Execution — esecuzione tramite task pianificati e file malevoli

    - Persistence — task pianificati per garantire la sopravvivenza al riavvio
    - Defense Evasion — masquerading, sandbox evasion, file offuscati
    - Discovery — raccolta di informazioni sul sistema (GUID, nome computer, lingua)
    - C&C — comunicazione su porte non standard con server di comando e controllo
- **Rischio:** malware avanzato con capacità di evasione, persistenza e comunicazione con infrastruttura di comando remoto





4 - Conclusioni

L'analisi tramite sandbox ANY.RUN ha permesso di identificare due minacce distinte . Il primo caso riguarda uno script PowerShell sospetto con comportamento da DNS Changer, capace di modificare le impostazioni di rete della vittima. Il secondo caso è significativamente più grave: un malware classificato come pienamente malevolo che si camuffa da software legittimo, installa componenti nascosti nel sistema e comunica con server esterni.

In entrambi i casi si raccomanda l'isolamento immediato delle macchine , la rimozione dei file identificati e un'analisi completa dei sistemi per verificare l'eventuale presenza di ulteriori componenti malevoli non ancora rilevati.